

Unraveling Unicode: A Bag of Tricks for Bug Hunting (English translation)

Unraveling Unicode: A Bag of Tricks for Bug Hunting - Author not stated, Publisher not stated.

- Published: date not stated
- Original: <<https://www.blackhat.com/presentations/bh-usa-09/WEBER/BHUSA09-Weber-UnicodeSecurityPreview-SLIDES.pdf>>
- Current location: <<https://blackhat.com/presentations/bh-usa-09/WEBER/BHUSA09-Weber-UnicodeSecurityPreview-SLIDES.pdf>>
- Preserved from: <https://blackhat.com/presentations/bh-usa-09/WEBER/BHUSA09-Weber-UnicodeSecurityPreview-SLIDES.pdf> (live) on 2026-08-08
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content (translated into English)

Machine translation of [unraveling-unicode-bag-tricks-bug-hunting.md](#), which holds the source's own words. Code, payloads, type names, URLs and CVE identifiers were masked before translating and restored after, so they are byte-identical to the original.

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Unraveling Unicode: A Bag of Tricks for Bug Hunting Black Hat USA July 2009

Chris Weber www.lookout.net chris@casabasecurity.com Casaba Security Can you tell the difference?

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber How about now?

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber The Transformers When good input turns bad

<script> becomes <script>

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Agenda

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Transformations Agenda

• Unicode crash course • Root Causes • Attack Vectors • Tools – Find Unicode issues in Web-testing – Visual Spoofing Detection

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Transformations Agenda

• Unicode crash course • Root Causes • Attack Vectors • Tools

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Crash Course The Unicode Attack Surface

• End users • Applications • Databases • Programming languages • Operating Systems

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Crash Course Unthink it

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Crash Course

• A large and complex standard code points canonical mappings encodings decomposition types categorization case folding normalization best-fit mapping binary properties 17 planes case mapping private use ranges conversion tables script blocks bi-directional properties escapings

Black Hat USA - July 2009 © 2009 Chris Weber Unicode Crash Course Code pages and charsets Shift_jis Gb2312 ISCII Windows-1252 ISO-8859-1 EBCDIC 037

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Crash Course Ad Infinitum

• Unicode can represent them all • ASCII range is preserved – U+0000 to U+007F are mapped to ASCII

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Crash Course Code points

• Unicode 5.1 uses a 21-bit scalar value with space for over 1,100,000 code points:

U+0000 to U+10FFFF

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Crash Course Code Points

A = U+0041

Every character has a unique number

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Crash Course A U+0041

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Crash Course f U+017F

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Crash Course Encodings

UTF-8 – variable width 1 to 4 bytes (used to be 6) UTF-16 – Endianess – Variable width 2 or 4 bytes – Surrogate pairs! UTF-32 – Endianess – Fixed width 4 bytes – Fixed mapping, no algorithms needed

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Crash Course Encodings and Escape sequences

U+FF21 FULLWIDTH LATIN CAPITAL LETTER A

%EF%BC%A1 Ａ Ａ \xEF\xBC\xA1 \uFF21 Black Hat USA - July 2009
www.casabasecurity.com © 2009 Chris Weber Unicode Transformations Agenda

- Unicode crash course • Root Causes • Attack Vectors • Tools

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Transformations Agenda

- Unicode crash course • Root Causes • Attack Vectors • Tools

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Transformations Overview • Unicode crash course • Root Causes – Visual Spoofing and IDN's – Best-fit mappings – Normalization – Overlong UTF-8 – Over-consumption – Character substitution – Character deletion – Casing – Buffer overflows – Controlling Syntax – Charset transformations – Charset mismatches • Tools

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Visual Spoofing

- Over 100,000 assigned characters • Many lookalikes within and across scripts

AAA

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Attack Vectors IDN homograph attacks

Some browsers allow .COM IDN's based on script family – (Latin has a big family)

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Attack Vectors IDN homograph attacks

Safari

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Attack Vectors IDN homograph attacks

Opera

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Attack Vectors IDN homograph attacks

www.google.com is not www.goo le.com

Latin Latin U+0069 U+0261

g Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes The state of International Domain Names

ICANN guidelines v2.0 Deny-all default seems to – Inclusion-based be the right concept.

– Script limitations A script can cross many – Character limitations blocks. Even with limited script choices, there's plenty to choose from.

Great for domain labels, but sub domain labels still open to punctuation and syntax spoofing.

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Attack Vectors Visual spoofing Vectors

SOLIDUS U+002F

(Normalized to a / U+002F)

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Attack Vectors IDN Syntax Spoofing with / lookalikes

<http://www.google.com> path file.nottrusted.org

Katakana No U+FF89

(However punctuation not required...)

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Attack Vectors The Invisibles

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Attack Vectors Visual Spoofing with Bidi Explicit Directional Overrides

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Best-fit mappings

Commonly occur in charset transformations and even innocuous API's Impact: Filter evasion, Enable code execution

When σ becomes s U+03C3 GREEK SMALL LETTER SIGMA When ' becomes ' U+2032 PRIME

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Guidance for Best-Fit mappings

- Scrutinize character/charset manipulation API's • Use EncoderFallback with System.Text.Encoding
- Set WC_NO_BEST_FIT_CHARS flag with WideCharToMultiByte() • Use Unicode end-to-end

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Case Study: Social Networking Best-fit mappings

• A popular social networking site in 2008 • Implemented complex filtering logic to prevent XSS – Attack: Filter evasion, code execution – Exploit: Bypass filtering logic with best-fit mappings to leverage cross-site scripting – Root Cause: best-fit mappings

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Case Study: Social Networking Best-fit mappings

-moz-binding() was not allowed, but.... -[U+ff4d]oz-binding() would best-fit map!

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Normalization

Normalizing strings after validation is dangerous Impact: Filter evasion, Enable code execution

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Normalization

ı becomes I + `

U+0130 U+0049 U+0307

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Normalization

But are there dangerous characters? You bet... with NFKC and NFKD you could control HTML or other parsing

becomes <

U+FE64 U+003C

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Normalization

becomes <

U+FE64 U+003C

toNFKC("<script>") = "<script>"

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Guidance for Normalization

Normalize strings before validation NFKC first defense against Visual spoofing

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Non-shortest form UTF-8

Non-shortest or overlong UTF-8 Impact: Filter evasion, Enable code execution

Application gets %C0%A7 OS/Framework sees %27 Database gets '

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Guidance for Non-shortest form UTF-8

- Unicode specification forbids – Generation of non-shortest form – Interpretation of non-shortest form for BMP
- Validate UTF-8 encoding (throw on error)

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Attack Vectors Directory traversal

How many ways can you say ../

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Attack Vectors

../

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Handling the Unexpected

- Unassigned code points – U+2073
- Illegal code points – Half a surrogate pair
- Code points with special meaning – U+FEFF is the BOM
- Impact: Filter evasion, Enable code execution

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Handling the Unexpected: Over-consumption

Over-consuming ill-formed byte sequences

- Big problem with MBCS lead bytes

<41 C2 3E 41> becomes <41 41>

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Handling the Unexpected: Over-consumption

` "onerror="alert(1)"<br />`

becomes

``

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Handling the Unexpected: Character-substitution

Correcting insecurely rather than failing – Substituting a ‘.’ or a ‘/’ would be bad

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Handling the Unexpected: Character-deletion

“deletion of noncharacters” (UTR-36)

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Handling the Unexpected: Character-deletion

`<scr[U+FEFF]ipt>` becomes `<script>`

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Solutions for Handling the Unexpected

- Fail or error
- Use U+FFFD instead – A common alternative is ‘?’, which can be safe

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Attack Vectors Filter evasion

- Bypass filters, WAF’s, NIDS, and validation • Exploit delivery techniques – E.g. Cross-site scripting (buffer overflow of the Web)

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Case Study: Apple and Mozilla

Safari and Firefox BOM consumption – Attack: Filter evasion, code execution – Exploit: Bypass filtering logic with specially crafted strings to leverage cross-site scripting – Root Cause: Character deletion

`<a href="java[U+FEFF]script:alert(„XSS ")>`

Can be nastier:

`<a h[U+FEFF]ref="java[U+FEFF]script:al[U+FEFF]ert(„XSS ")>`

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber A Closer Look: The BOM BOM U+FEFF

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Casing

- Attackers manipulate casing operations to inject otherwise prohibited characters • Casing can multiply the buffer sizes needed • Impact: Filter evasion, Enable code execution

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Casing

`toLowerCase("i") == "i"`

`toLowerCase("script") == "script"`

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Casing

`len(x) != len(toLower(x))`

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Guidance for Casing

- Perform casing operations before validation
- Leverage existing frameworks and API's – ICU, .Net

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Buffer Overflows

- Incorrect assumptions about string sizes (chars vs. bytes)
- Improper width calculations
- Impact: Enable code execution

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Buffer Overflows

Casing - maximum expansion factors

Operation UTF Factor Sample Lower 8 1.5 U+023A 16, 32 1 A U+0041 Upper 8, 16, 32 3 ĩ U+0390
Source: Unicode Technical Report #36

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Buffer Overflows

Normalization- maximum expansion factors

Operation UTF Factor Sample 8 3X U+1D160 NFC 16, 32 3X ѵ U+FB2C 8 3X ĩ U+0390 NFD 16, 32 4X U+1F82 8 11X NFKC/NFKD U+FDFA 16, 32 18X Source: Unicode Technical Report #36

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Guidance for Buffer Overflows

- Know the difference between bytes and chars
- Secure coding
- Leverage existing frameworks and API's – ICU, .Net

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Controlling Syntax

- White space and line breaks – E.g. when U+180E acts like U+0020
- Quotation marks
- Impact: Filter evasion, Enable code execution

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Attacks and Exploits Controlling syntax

- Manipulate HTML parsers and javascript interpreters
- Control protocols

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Case Study: Opera

- Unicode formatter characters exploited for XSS – Damage: Filter evasion, controlling syntax – Exploit: Bypass filtering logic with specially crafted characters to leverage cross-site scripting. – Root Cause: Interpreting “white space” – A problem with HTML 4.0 spec?

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Case Study: Opera

`<a href=#[U+180E]onclick=alert(>`

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Case Study: Opera

MVS U+180E

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Guidance for Controlling Syntax

- Question specifications • Be careful...

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Specifications

1. Character stability

– IDNA/Nameprep based on Unicode 3.2

1. Designs

– Specs are carefully designed but not always perfect • This could have been a problem: – “When designing a markup language or data protocol, the use of U+FEFF can be restricted to that of Byte Order Mark. In that case, any U+FEFF occurring in the middle of the file can be ignored, or treated as an error.” – HTML 4.01 • Defines four whitespace characters and explicitly leaves handling other characters up to implementer.

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Charset Transformations

- Converting between charsets is dangerous • Mapping tables and algorithms vary across platforms • Impact: Filter evasion, Enable code execution, Data-loss

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Guidance for Charset Transformations

- Avoid if possible • Use Unicode as the broker • Beware the PUA mappings • Transform, case, and normalize prior to validation and redisplay

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Charset Mismatches

- Some charset identifiers are ill-defined • Vendor implementations vary • User-agents may sniff if confused • Attackers manipulate behavior • Impact: Filter evasion, Enable code execution

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Charset Mismatches

Content-Type: charset=ISO-8859-1

Attacker-controlled input

```
<meta http-equiv="Content-Type" content="text/html; charset=shift_jis"/>
```

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Root Causes Guidance for Charset Mismatches

- Force UTF-8 • Error if uncertain

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Transformations Agenda

- Unicode crash course • Root Causes • Attack Vectors • Tools

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Unicode Transformations Agenda

- Unicode crash course • Root Causes • Attack Vectors • Tools

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Tools

- Watcher – Passive Web-app security testing and auditing
- Unibomber – XSS autopwn testing tool

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Tools Watcher – Some of the Passive Checks Included • Unicode transformation hot-spots • User-controlled HTML • Cross-domain issues • Insecure cookies • Insecure HTTP/HTTPS transitions • SSL protocol and certificate issues • XSS hot-spots • Flash issues • Silverlight issues • Information disclosure

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Tools

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Tools Watcher - Web-app Security Testing and Auditing

<http://websecuritytool.codeplex.com>

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Tools Unibomber–runtime XSS testing tool

- Deterministic testing • Auto-inject payloads • Unicode transformers – < > ' ", etc. • Detect transformations and encoding hotspots

Black Hat USA - July 2009 www.casabasecurity.com © 2009 Chris Weber Thank you! Casaba Security www.casabasecurity.com Chris Weber Blog: www.lookout.net Email: chris@casabasecurity.com LinkedIn: <http://www.linkedin.com/in/chrisweber>